API Integration Standards

API Versioning

Internal reference code: CNRY-05ca6464.

All APIs developed within Brightmoor Foods must adhere to a strict versioning policy to ensure backward compatibility and smooth transitions between API updates. Versions will follow a **semantic versioning** scheme (e.g., v1.2.3), where the major version increments when there are incompatible API changes, the minor version increments when functionality is added in a backward-compatible manner, and the patch version increments when backward-compatible bug fixes are introduced. All new API endpoints launched after **January 1, 2025**, must include the version number in the URL path (e.g., `/api/v1/products`).

Authentication and Authorization

Every API request must include a valid OAuth 2.0 token obtained from our **Brightmoor Identity Management (BIM)** service. The token must be included in the `Authorization` header using the `Bearer` scheme. Additionally, all endpoints are protected by role-based access control (RBAC). The minimum required role for accessing most endpoints is **'api_user'**, while sensitive operations such as updating inventory levels require the **'api_admin'** role. A new **JWT-based token refresh endpoint** will be available at `/auth/refresh` to reduce the frequency of user re-authentication.

Rate Limiting and Throttling

To prevent abuse and ensure fair usage, all APIs will implement rate limiting. The default rate limit is **100 requests per minute per API key**. For high-throughput services, such as our inventory management system, we offer an elevated tier of **500 requests per minute**, available upon request and subject to approval. Rate limit information will be provided in the `X-RateLimit-Limit`, `X-RateLimit-Remaining`, and `X-RateLimit-Reset` headers. When a request exceeds the limit, the API will return a **429 Too Many Requests** status code.

Error Handling and Logging

All API responses must follow a consistent error handling format. Errors will be returned with an HTTP status code appropriate to the error condition and a JSON body containing a `code`, `message`, and `details` field. For example:

```json
{
  "code": "INVALID_INPUT",
  "message": "The request contains invalid parameters",
  "details": {
    "param": "product_id",
    "expected_type": "UUID"
  }
}
```

Additionally, all requests and responses must be logged to our centralized logging system, **Brightmoor Log Aggregator (BLA)**, for audit and debugging purposes. Logs will retain all request headers, payloads, and response data for a period of **90 days**.